Midas mToken Min Balance Audit v2

Côme du Crest

2026-07-29

Table of contents

- Table of contents
- Midas mToken Min Balance Audit v2
  - Scope
  - Context
  - Status
  - Legal Information And Disclaimer

Midas mToken Min Balance Audit v2

This document presents the findings of a smart contract audit conducted by Côme du Crest.

For any inquiry contact me by email at come.ducrest@gmail.com or via telegram @ComeduCrest.

Scope

The scope includes the two contracts `mTokenMinBalance` and `mTokenPermissionedMinBalance` of `PR#242` of `midas-apps/contracts`. The last commit reviewed in this PR is `0xe1488bb`.

After the initial audit, the `mWin` token has been updated to implement a min balance in commit `0x98bb0ce`. This commit has been reviewed. Additionally, a bug has been found due to fee being applied after a burn and preventing transfers that should bring the balance down to zero. This bug has been fixed in `PR#248` and has been reviewed as of commit `0x0fb1ecb`.

The complete list of inspected contracts is:

- mTokenMinBalance.sol
- mTokenPermissionedMinBalance.sol
- products/mWIN/MWinCustomAggregatorFeed.sol
- products/mWIN/mWIN.sol
- RedemptionVault.sol
- RedemptionVaultWithAave.sol
- RedemptionVaultWithBUIDL.sol
- RedemptionVaultWithMorpho.sol
- RedemptionVaultWithMToken.sol
- RedemptionVaultWithUSTB.sol

Context

The two new contracts enforce a new `_afterTokenTransfer()` hook that validates the resulting balance of the `to` and `from` address are either zero or above 1e18. The `_afterTokenTransfer()` is called after transfers, mints, and burns by inherited `ERC20Upgradeable()`.

The permissioned contract additionally calls `mTokenPermissioned._beforeTokenTransfer()` in its `_beforeTokenTransfer()` hook to enforce the `to` and `from` addresses are permissioned.

Since the only way to update the balance of a user is through transfers, mints, or burns I don't see a way for a user to hold an invalid balance.

Do note however that if mTokens are upgraded to `mTokenMinBalance`, balances that are already in between zero and 1e18 will remain there. Additionally, balance exempt from the threshold will remain below the threshold when their exemptions are removed.

Storage collision

After the audit, mWIN has been updated from `is mTokenPermissioned` to `is mTokenPermissionedMinBalance` in commit `0x98bb0ce` which updates the storage layout from:

`mWIN is mTokenPermissioned`

- mToken storage
- 50 gap in mTokenPermissioned

to:

`mWIN is mTokenPermissionedMinBalance`

- mToken storage
- 50 gap in mTokenMinBalance
- 50 gap in mTokenPermissioned

Which is theoretically a storage collision but it occurs only on empty gap storage variable and should not cause any issue.

Transfer before burn

The issue identified after the issue is that when RedemptionVault transfers or burns mToken from the user they get the amount without fee before the fee. Knowing the fee are expected to be smaller than the amount without fees this may bring the following problem during a redemption:

- user has 1.1 mToken
- fee is 0.05 mToken
- amount without fee: 1.05 mTokens
- Vault burns 1.05 mToken before the fee transfer resulting in a balance of 0.05 mToken causing a revert due to balance below minimum

The chosen fix is to transfer/burn the fee before the main part of the redemption.

I believe it would have been cleaner to exempt the vault from min balance and transfer the total handled amount from the user to the vault that can burn / pay out fee without worrying about minimum limits.

Status

No issues have been found.

The report has been sent to the protocol team.

Legal Information And Disclaimer

1. This report is based solely on the information provided by Midas (the “Company”), with the assumption that the information provided is authentic, accurate, complete, and not misleading as of the date of this report. The auditor has not conducted any independent enquiries, investigations or due diligence in respect of the Company, its business or its operations.
2. Changes to the information contained in the documents, repositories and any other materials referenced in this report might affect or change the analysis and conclusions presented. The auditor is not responsible for monitoring, nor will we be aware of, any future additions, modifications, or deletions to the audited code. As such, the auditor does not assume any responsibility to update any information, content or data contained in this report following the date of its publication.
3. This report does not address, nor should it be interpreted as addressing, any regulatory, tax or legal matters, including but not limited to: tax treatment, tax consequences, levies, duties, data privacy, data protection laws, issues relating to the licensing of information technology, intellectual property, money laundering and countering the financing of terrorism, or any other legal restrictions or prohibitions. The auditor disclaims any liability for omissions or errors in the findings or conclusions presented in this report.
4. The views expressed in this report are solely my views regarding the specific issues discussed within this report. This report is not intended to be exhaustive, nor should it be construed as an assurance, guarantee or warranty that the code is free from bugs, vulnerabilities, defects or deficiencies. Different use cases may carry different risks, and integration with third-party applications may introduce additional risks.
5. This report is provided for informational purposes only and should not be used as the basis for making investment or financial decisions. This report does not constitute investment research and should not be viewed as an invitation, recommendation, solicitation or offer to subscribe for or purchase any securities, investments, products or services. The auditor is not a financial advisor, and this report does not constitute financial or investment advice.
6. The statements in this report should be considered as a whole, and no individual statement should be extracted or referenced independently.
7. To the fullest extent permitted by applicable laws, the auditor disclaims any and all other liability, whether in contract, tort, or otherwise, that may arise from this report or the use thereof.